

주 의 사 항

1. 제 목 : 전산시스템 관리 부적정

2. 관계기관 : ★★★★★병원

3. 내 용 : ★★★★★병원에서는 전자의무기록을 효율적이고 통일적으로 작성·관리·활용하기 위해 전자의무기록(Electronic Medical Record, 이하 “EMR”라 한다)시스템과 환자의 의료영상정보를 전자적으로 관리하기 위한 의료영상저장전송시스템(Picture Archiving Communication System, 이하 “PACS”라 한다)을 구축·운영하고 있습니다.

가. EMR 진료기록 열람에 대한 법적 고지

「의료법」제23조 제3항 및 제87조 제1항의 규정에 따르면 누구든지 정당한 사유 없이 전자의무기록에 저장된 개인정보를 탐지하거나 누출할 경우 5년 이하의 징역 또는 5천만 원 이하의 벌금에 처하도록 되어 있습니다.

따라서, 정당한 사유 없이 환자에 대한 전자의무기록 무단 열람 행위는 형사처벌 대상이 될 수도 있는 사항이므로 직원들의 개인정보 보호 의식 제고와 무단 열람에 대한 경각심 제고를 위하여 위반행위에 따른 벌칙사항을 알려줄 필요가 있습니다.

그런데 EMR 진료기록부 열람 과정을 확인한 결과, 타과 소관의 환자를 열람 시 사유를 선택하고 진행하도록 되어 있는데 무단 열람 시 받을 수 있는 벌칙사항 안내 등 경각심을 줄 수 있는 내용에 대한 고지가 부족한 것으로 확인되었습니다.

나. EMR 진료기록 열람내용 관리

「개인정보 보호법 시행령」 제30조에 따르면 개인정보처리자는 개인정보에 대한 접근통제 및 접근 권한의 제한조치를 취해야 하며, 개인정보 침해사고 발생에 대응하기 위한 접속기록의 보관 및 위조·변조 방지를 위한 조치를 취하도록 되어 있습니다.

따라서 EMR 사용자가 진료기록부를 열람할 시에는 접근통제를 해야 하고, 접속기록을 보관하여 개인정보 침해 사고 발생에 효과적으로 대응할 수 있어야 합니다.

그런데 EMR 사용자의 진료기록부 열람 실태를 확인한 결과,

① 의무기록뷰어에서 타과 진료기록을 열람할 시에는 열람신청을 하게 되면 의무기록실의 통제 절차를 거쳐서 진료기록을 볼 수 있도록 되어있어 적절한 통제장치가 마련되어 있으나, 신청 승인 후 어떤 종류의 개인정보 열람 작업을 했는지는 기록을 저장하지 않고 있었습니다.

② 의사메인화면에서는 타과 진료기록을 열람할 시에 조회사유를 선택하면 승인 절차 없이 환자의 진료기록을 열람하도록 되어 있어, 조회사유만 기록하고 어떤 종류의 개인정보 열람 작업을 했는지는 기록을 저장하지 않고 있었습니다.

[표 1] 의무기록 열람 경로

①의무기록뷰어	②의사메인
	
▶ 의무기록뷰어 오픈 → 열람사유입력 (집담회, 연구,검사확인,기타) → 의무기록실 승인통제 → 열람 (진료 열람내역 미기록)	▶ 의사메인 오픈 → 열람사유선택 팝업(타과환자 선택시) → 조회사유 선택(추가오더,미비기록작성, 연구,교육 등) → 열람 (진료 열람내역 미기록)

다. 진료기록 발급 요건 관리

「의료법」제21조에는 환자가 아닌 다른 사람에게 환자에 관한 기록을 열람하게 하거나 그 사본을 내주는 등 내용을 확인할 수 있게 해서는 아니 되지만, 환자의 가족이나 대리인 등이 「의료법 시행규칙」 제13조의3에서 정하고 있는 열람요건을 충족할 시에는 그 기록을 열람하게 하거나 사본을 교부할 수 있도록 정하고 있습니다.

[표 2] 진료기록 열람 등의 요건

신청 주체	제출 서류
친족	신청자 신분증사본, 가족관계 증명서등(친족관계임을 확인할 수 있는 서류), 환자가 자필 서명한 동의서, 환자의 신분증 사본
대리인	신청자 신분증사본, 환자가 자필 서명한 동의서, 위임장, 환자의 신분증 사본,

따라서, 환자 본인이 아닌 제3자가 진료기록부를 열람하거나 그 사본을 요청할 시에는 위 [표 2]에서 정한 요건에 충족하는 서류가 제출되었을 때에 한하여 열람 및 사본발급이 가능하도록 관리해야 합니다.

그런데 '16. 1. 1. ~ '16.12.31. 까지 ★★★★★병원에서 발급된 진료기록 2,104건 확인결과 372건에는 환자 신분증만 보유하고 가족관계 증명서, 환자 자필서명 동의서 등 추가로 필요한 서류를 구비하지 못하였는데도 진료기록이 발급된 것으로 확인되었습니다.

라. PACS 사용자 ID관리

「정보보안업무 처리지침」 제8조에서는 보직변경, 퇴직 등 인사이동 시 관련 정보시스템 접근권한을 조정하도록 되어 있고, ★★★★★병원 「의무기록 정보 접근권한 지침」에서는 퇴사한 직원ID는 삭제되어야 한다고 되어 있습니다.

따라서, PACS 사용자로 등록된 직원ID중에 퇴사자가 발생할 시에는 즉시 삭제조치가 되어야 합니다.

그런데 PACS에 등록된 직원ID를 확인한 결과 퇴직자임에도 불구하고 삭제조치가 되지 않은 직원ID 42건이 확인되었습니다. (붙임1 참고)

마. PACS 판독결과문 전자서명 관리

「의료법」 제23조에 따르면 의료인이나 의료기관 개설자는 진료기록부 등을 「전자서명법」에 따른 전자서명이 기재된 전자문서(이하 "전자의무기록"이라 한다)로 작성·보관할 수 있도록 되어 있으며, 「전자서명법」 제2조에는 전자서명은 서명자가 전자문서에 서명하였음을 나타내는 당해 전자문서에 첨부되거나 논리적으로 결합된 전자적 형태의 정보라고 되어 있습니다.

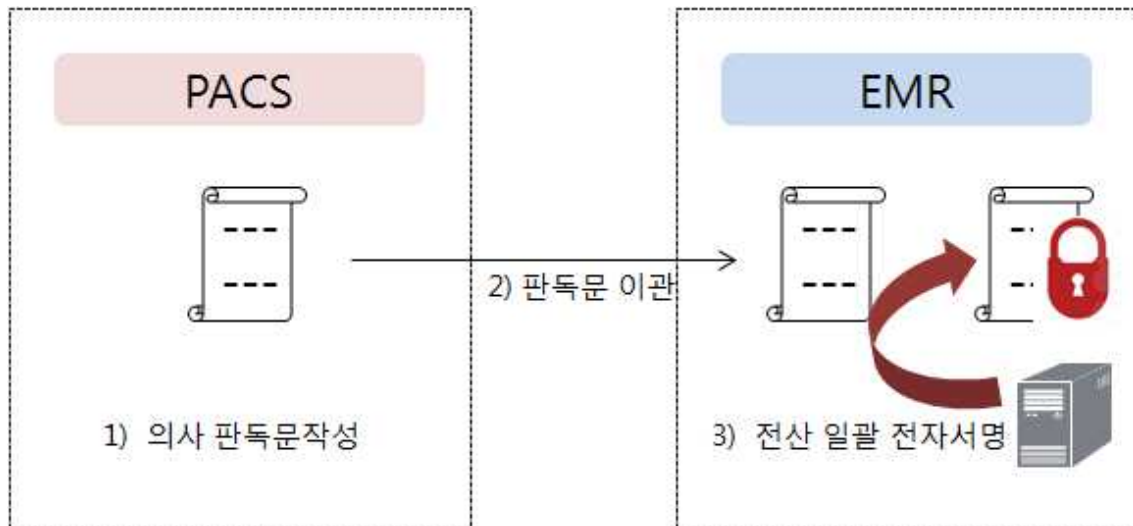
따라서, PACS에서 환자의 영상정보를 의사가 판독²⁾하여 전자문서로 작성하여 보관할 때에는, 판독한 의사의 전자서명도 함께 작성·보관하여야 합니다.

그런데 ★★★★★병원 PACS의 판독문을 확인한 결과, PACS에서 작성된 판독

2) 영상의학과에서 검사한 X-ray검사, 컴퓨터단층촬영(CT)검사, 자기공명영상촬영(MRI)검사, 초음파검사 등의 영상을 영상의학과 전문의가 진단 및 진료자문을 하는 것을 말한다.

결과문을 전자의무기록시스템(Electronic Medical Record, 이하 “EMR”라 한다)으로 전송한 뒤에 여기서 전자서명작업을 별도의 프로그램을 통하여 2차적으로 일괄 실시하는 방식으로 진행하고 있었습니다.

[표 1] 현행 판독문 전자서명 개념도



바. PACS 진료기록 열람 관리

「의료법」 제23조제3항에 따르면 누구든지 정당한 사유 없이 전자의무기록에 저장된 개인정보를 탐지하거나 누출·변조 또는 훼손하여서는 아니 된다고 하고 있습니다.

따라서, PACS 시스템은 정당한 사유가 없을 때에는 무단으로 관련 진료기록을 열람할 수 없도록 접속을 제한·차단하도록 시스템이 구성되어야 하며, 접속한 경우에는 접속 기록이 남아 향후 이를 통제할 수 있도록 시스템이 구축되어야 합니다.

그런데 PACS에서는 로그인만 하게 되면, 별다른 통제장치 없이 타과 소관의 CT, MRI와 같은 영상자료를 열람할 수 있었고, 판독결과문 등도 확인이 가능하였을 뿐 아니라 EMR을 통해 PACS에 접속한 경우에는 EMR에서 로그아웃하더라도 PACS에서는 자동으로 로그아웃되지 않아 다른 사람이 이를 무단으로 열람할 가능성이 있었으며, 열람을 한 기록도 남지 않은 것으로 확인되었습니다.

4. 조치할 사항

○ ★★★★★병원장은

- 타 진료과 소관 환자에 대한 진료기록 열람 시 정당한 사유가 없을 경우 받게 되는 벌칙을 사전 고지하여 위반 사례 예방할 수 있도록 조치하시기 바라며,(권고)
- EMR진료기록 열람 시 열람 내용에 대한 기록도 관리할 수 있도록 검토(통보)
- 향후 진료기록을 발급할 때에는 정해진 요건을 충족하도록 관리하고, 업무담당자에게 「주의」를 촉구하시기 바라며,(주의)
- 퇴사자 발생 시 PACS에 등록된 ID도 즉시 삭제할 수 있도록 관리하시기 바라며,(권고)
- 향후에는 PACS시스템에서 전자서명이 직접 이루어질 수 있도록 시스템 개선 계획을 마련하시기 바라며,(통보)
- EMR을 통해 PACS에 접속한 경우에는 EMR에서 로그아웃되면 PACS에서도 자동으로 로그아웃될 수 있도록 시스템 개선시 반영하시기 바랍니다.(통보)

[붙임] PACS 퇴사일자 누락리스트

순번	사번	PACS 퇴사일	퇴사일자
1	*****	-	2008-02-29 0:00
2	*****	-	2008-02-29 0:00
3	*****	-	2013-06-30 0:00
4	*****	-	2015-01-02 0:00
5	*****	-	2012-09-20 0:00
6	ZGS040	-	2014-11-06 0:00
7	ZGS045	-	2014-11-06 0:00
8	ZDR007	-	2015-01-30 16:02
9	ZGS034	-	2014-11-06 0:00
10	ZNM001	-	2013-07-08 0:00
11	ZDR003	-	2015-01-30 16:02
12	ZDR006	-	2015-01-30 16:02
13	ZDR009	-	2015-03-03 8:35
14	ZGS020	-	2013-04-06 0:00
15	ZDR005	-	2015-01-30 16:02
16	ZGS036	-	2014-11-06 0:00
17	ZGS031	-	2014-11-06 0:00
18	ZGS022	-	2014-06-27 17:00
19	ZGS015	-	2013-07-01 11:33
20	ZGS014	-	2013-07-01 11:33
21	ZGS013	-	2013-07-01 11:33
22	ZGS004	-	2013-07-01 11:33
23	ZGS018	-	2013-04-06 0:00
24	ZGS019	-	2013-04-06 0:00
25	ZGS011	-	2013-07-01 11:33
26	ZGS012	-	2013-07-01 11:33
27	ZDR001	-	2015-01-30 16:02
28	ZDR002	-	2015-01-30 16:02
29	ZGS003	-	2013-07-01 11:33
30	ZGS008	-	2013-07-01 11:33
31	ZGS035	-	2014-11-06 0:00
32	ZGS010	-	2013-07-01 11:33
33	ZGS046	-	2014-11-06 0:00
34	ZGS001	-	2013-07-01 11:33
35	ZGS006	-	2013-07-01 11:33
36	ZDR008	-	2015-02-02 8:44
37	ZGS027	-	2014-11-06 0:00
38	181747	-	2016-08-19 0:00
39	ZGS016	-	2013-07-01 11:33
40	ZGS017	-	2013-07-01 11:33
41	ZDR004	-	2015-01-30 16:02
42	ZGS023	-	2013-04-06 0:00